Chapter 4 / Capítulo 4

Case study / Caso de estudio: Pinkwater Bank

Fuente: CISA Official Review Manual, ISACA. Texto y clave proporcionados por el usuario. Traducción no oficial. Se incluyen las explicaciones completas de todas las alternativas. Los guiones son explicaciones propias.

English: Case Study An IS auditor has been asked to represent the internal audit department of her organization on a task force to define the requirements for a new branch automation project for Pinkwater Bank, a community bank with 16 branches. This new system would handle deposits, loans and confidential customer information. The branches are located within the same geographic area, so the director of branch operations has suggested using a microwave radio system to provide connectivity due to its low cost of operation and the fact that it is a private (not public) network. The director also has strongly suggested that it would be preferable to provide each branch with a backup connection to the Internet using a direct coaxial cable (from the local cable television provider) if the microwave system develops a fault. The direct Internet connection would also be connected to a wireless access point at each branch to provide free wireless access to customers. The director also asked that each branch be provided with mail and application servers administered by each branch's administrative manager. The IS auditor was informed by the bank's IT manager that the cable service provider would encrypt all traffic sent over the direct coaxial connection to the Internet. Following the preliminary work, Pinkwater Bank develops revised BCPs and DRPs for its headquarters facility and network of 16 branch offices. The current plans have not been updated in more than eight years, during which time the organization has grown by over 300 percent. At the headquarters facility, there are approximately 750 employees. These individuals connect over a LAN to an array of more than 60 application, database and file print servers in the corporate data center and over a frame relay network to the branch offices. Traveling users access corporate systems remotely by connecting over the Internet using a VPN. Users at headquarters and branch offices access the Internet through a firewall and proxy server in the data center. Critical applications have an RTO of between three and five days. Branch offices are 30 to 50 miles from one another, with none closer than 25 miles to the headquarters facility. Each branch office has between 20 and 35 employees, plus a mail server and a file/print server. Backup media for the data center are stored at a third-party facility that is 35 miles away. Backups for servers located at the branch offices are stored at nearby branch offices using reciprocal agreements. Current contracts with a third-party hot site provider include 25 servers, work area space equipped with desktop computers to accommodate 100 individuals, and a separate agreement to ship up to two servers and 10 desktop computers to any branch office that declares an emergency. The contract term is three years, with equipment upgrades occurring at renewal time. The hot site provider has multiple facilities throughout the country if the primary facility is used by another customer or rendered unavailable by the disaster. Senior management desires that any enhancements be as cost-effective as possible.

Español: Un auditor de SI ha sido designado para representar a auditoría interna en un equipo que definirá los requisitos de un nuevo proyecto de automatización de sucursales de Pinkwater Bank, un banco comunitario con 16 sucursales. El sistema manejará depósitos, préstamos e información confidencial de clientes.

Las sucursales están en la misma área geográfica. El director de operaciones propone conectarlas mediante radio de microondas por su bajo costo y porque es una red privada. También propone una conexión de respaldo a Internet mediante cable coaxial del proveedor local de televisión por cable si falla el sistema de microondas.

La conexión directa a Internet también se conectaría a un punto de acceso inalámbrico en cada sucursal para ofrecer Wi-Fi gratuito a los clientes. El director solicita servidores de correo y aplicaciones administrados por el gerente administrativo de cada sucursal. El gerente de TI informa que el proveedor de cable cifraría todo el tráfico transmitido mediante la conexión coaxial.

Tras el trabajo preliminar, el banco elabora planes revisados de continuidad del negocio (BCP) y recuperación ante desastres (DRP) para su sede y sus 16 sucursales. Los planes actuales llevan más de ocho años sin actualizarse, período en el que la organización creció más de 300 %. La sede tiene aproximadamente 750 empleados, conectados mediante una LAN a más de 60 servidores de aplicaciones, bases de datos, archivos e impresión del centro de datos, y mediante Frame Relay a las sucursales. Los usuarios que viajan acceden por Internet mediante VPN. Los usuarios de la sede y las sucursales acceden a Internet mediante un firewall y un servidor proxy del centro de datos.

Las aplicaciones críticas tienen un RTO de entre tres y cinco días. Las sucursales están separadas entre sí por 30 a 50 millas y ninguna está a menos de 25 millas de la sede. Cada sucursal tiene entre 20 y 35 empleados, un servidor de correo y uno de archivos e impresión. Los respaldos del centro de datos se almacenan en instalaciones de un tercero a 35 millas. Los respaldos de las sucursales se almacenan en sucursales cercanas mediante acuerdos recíprocos.

Los contratos actuales con un proveedor externo de hot site incluyen 25 servidores, espacio de trabajo con computadoras para 100 personas y un acuerdo separado para enviar hasta dos servidores y diez computadoras a cualquier sucursal que declare una emergencia. El contrato dura tres años y el equipo se actualiza al renovarlo. El proveedor tiene varias instalaciones en el país si la principal está ocupada por otro cliente o queda inutilizable por el desastre. La alta dirección desea que las mejoras sean lo más rentables posible.

Question 1 / Pregunta 1

English: In reviewing the information for this project, what would be the MOST important concern regarding the use of microwave radio systems based on the above scenario?

A. Susceptibility to interception of transmitted data

B. Lack of available data transmission encryption solutions

C. Likelihood of a service outage

D. Cost overruns in implementation

Español: Según el escenario, ¿cuál sería la preocupación MÁS importante sobre el uso de sistemas de radio de microondas?

A. La susceptibilidad a la interceptación de los datos transmitidos.

B. La falta de soluciones disponibles de cifrado de transmisión de datos.

C. La probabilidad de interrupción del servicio.

D. Los sobrecostos de implementación.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: Lack of encryption is the most important concern since microwave radio systems are easy to tap.

Español: La falta de cifrado es la preocupación principal, ya que es fácil interceptar los sistemas de radio de microondas.

B. Incorrect / Incorrecta

English: Lack of scalability is important but not as important as ensuring the confidentiality and integrity of customer data.

Español: La falta de escalabilidad es importante, pero menos que garantizar la confidencialidad e integridad de los datos de los clientes.

C. Incorrect / Incorrecta

English: The likelihood of a service outage is important but not as important as ensuring the confidentiality and integrity of customer data.

Español: La probabilidad de interrupción del servicio es importante, pero menos que garantizar la confidencialidad e integridad de los datos de los clientes.

D. Incorrect / Incorrecta

English: Cost overruns in implementation are important but not as important as ensuring the confidentiality and integrity of customer data.

Español: Los sobrecostos de implementación son importantes, pero menos que garantizar la confidencialidad e integridad de los datos de los clientes.

Nota del material original: La opción B habla de soluciones de cifrado, pero su explicación habla de escalabilidad. Se conserva esa diferencia del material original.

Suggested speaking script / Guion sugerido

English: I choose A because customer data transmitted by radio must be protected against interception.

Español: Elegiría la A porque los datos de clientes transmitidos por radio deben protegerse contra la interceptación.

Question 2 / Pregunta 2

English: Which of the following would BEST reduce the likelihood of business systems being successfully attacked from the public Internet through the wireless network?

A. Scanning all connected devices for malware

B. Segmenting internal network and public Internet access through a firewalled subnet

C. Logging all access and issuing alerts for failed logon attempts

D. Limiting all network access to regular business hours and standard protocols

Español: ¿Qué reduciría MEJOR la probabilidad de que los sistemas del negocio sean atacados con éxito desde Internet a través de la red inalámbrica?

A. Analizar todos los dispositivos conectados en busca de malware.

B. Separar la red interna y el acceso público a Internet mediante una subred protegida por firewall.

C. Registrar todos los accesos y generar alertas por intentos fallidos de inicio de sesión.

D. Limitar el acceso a la red al horario laboral y a protocolos estándar.

Correct answer / Respuesta correcta: B

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Scanning for malware would not detect the use of investigative tools designed to harvest passwords or reveal network vulnerabilities.

Español: El análisis de malware no detectaría el uso de herramientas de investigación diseñadas para obtener contraseñas o revelar vulnerabilidades de la red.

B. Correct / Correcta

English: Isolating the wireless network by placing it on a firewalled subnet would best reduce the likelihood of attack.

Español: Aislar la red inalámbrica en una subred protegida por firewall reduciría mejor la probabilidad de ataque.

C. Incorrect / Incorrecta

English: Logging access would not prevent a successful attack.

Español: Registrar los accesos no impediría un ataque exitoso.

D. Incorrect / Incorrecta

English: Limiting access to normal business hours would not prevent a successful attack.

Español: Limitar el acceso al horario laboral no impediría un ataque exitoso.

Suggested speaking script / Guion sugerido

English: I choose B because separating customer Wi-Fi from the internal network limits paths for attacks.

Español: Elegiría la B porque separar el Wi-Fi de clientes de la red interna limita las vías de ataque.

Question 3 / Pregunta 3

English: When negotiating new contracts with the vendor, which of the following should the IS auditor recommend to management concerning the hot site in this situation?

A. Desktops at the hot site should be increased to 750.

B. An additional 35 servers should be added to the hot site contract.

C. All backup media should be stored at the hot site to shorten the RTO.

D. Desktop and server equipment requirements should be reviewed quarterly.

Español: Al negociar nuevos contratos con el proveedor, ¿qué debería recomendar el auditor sobre el hot site?

A. Aumentar a 750 las computadoras del hot site.

B. Añadir 35 servidores al contrato del hot site.

C. Almacenar todos los respaldos en el hot site para reducir el RTO.

D. Revisar trimestralmente los requisitos de computadoras y servidores.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Because not all employee job functions are critical during a disaster, it is not necessary to contract the same number of desktops at a recovery facility as the number of employees.

Español: No todas las funciones de los empleados son críticas durante un desastre; por ello, no es necesario contratar tantas computadoras en el centro de recuperación como empleados tenga la organización.

B. Incorrect / Incorrecta

English: Similarly, not every server is critical to the continued operation of the business. Only a subset will be required.

Español: Del mismo modo, no todos los servidores son críticos para mantener la operación del negocio. Solo se necesitará un subconjunto.

C. Incorrect / Incorrecta

English: Because there is no assurance that the hot site will not already be occupied, storing backup media at the facility would not be advisable. These facilities are generally not designed to provide extensive media storage, and frequent testing by other customers could compromise the security of the media.

Español: Como no hay garantía de que el hot site no esté ya ocupado, no es aconsejable almacenar allí los respaldos. Estas instalaciones normalmente no están diseñadas para almacenar grandes cantidades de medios, y las pruebas frecuentes de otros clientes podrían comprometer su seguridad.

D. Correct / Correcta

English: As equipment needs in a rapidly growing business are subject to frequent change, quarterly reviews are necessary to ensure that the recovery capability keeps pace with the organization.

Español: Las necesidades de equipos de una empresa en rápido crecimiento cambian con frecuencia. Por ello, se necesitan revisiones trimestrales para que la capacidad de recuperación se mantenga al ritmo de la organización.

Suggested speaking script / Guion sugerido

English: I choose D because recovery resources must change as the bank grows.

Español: Elegiría la D porque los recursos de recuperación deben actualizarse conforme crece el banco.

Question 4 / Pregunta 4

English: When negotiating new contracts with the vendor, which of the following should the IS auditor recommend to management concerning branch office recovery?

A. Add each of the branches to the existing hot site contract.

B. Ensure branches have sufficient capacity to back each other up.

C. Relocate all branch mail and file/print servers to the data center.

D. Add additional capacity to the hot site contract equal to the largest branch.

Español: Al negociar nuevos contratos con el proveedor, ¿qué debería recomendar el auditor sobre la recuperación de las sucursales?

A. Añadir cada sucursal al contrato de hot site existente.

B. Asegurar que las sucursales tengan capacidad suficiente para respaldarse entre sí.

C. Trasladar todos los servidores de correo, archivos e impresión de las sucursales al centro de datos.

D. Añadir al contrato del hot site capacidad equivalente a la sucursal más grande.

Correct answer / Respuesta correcta: B

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Adding each branch to the hot site contract would be far more expensive.

Español: Añadir cada sucursal al contrato del hot site sería mucho más costoso.

B. Correct / Correcta

English: The most cost-effective solution is to recommend that branches have sufficient capacity to accommodate critical personnel from another branch. Because critical job functions would represent only perhaps 20 percent of the staff from the affected branch, accommodations for only four to seven critical staff members would be needed.

Español: La solución más rentable es recomendar que las sucursales tengan capacidad para alojar al personal crítico de otra sucursal. Como las funciones críticas representarían quizá solo el 20 % del personal de la sucursal afectada, bastaría con acomodar entre cuatro y siete empleados críticos.

C. Incorrect / Incorrecta

English: Relocating branch servers to the data center could result in performance issues. It would not address the question of where to locate displaced employees.

Español: Trasladar los servidores de las sucursales al centro de datos podría generar problemas de rendimiento y no resolvería dónde ubicar a los empleados desplazados.

D. Incorrect / Incorrecta

English: Adding capacity to the hot site contract would not provide coverage, as hot site contracts base their pricing on each location covered.

Español: Añadir capacidad al contrato del hot site no proporcionaría cobertura, ya que el precio se basa en cada ubicación cubierta.

Suggested speaking script / Guion sugerido

English: I choose B because nearby branches can host essential staff at lower cost than covering every branch with a hot site.

Español: Elegiría la B porque otras sucursales pueden alojar al personal esencial a menor costo que contratar un hot site para cada sucursal.